Static Code Analysis

25/09/26

* This examines source code without executing the program.

Identifies
→ Coding errors & bugs.
→ Security vulnerabilities.
→ Duplicated Code.

* Static Analysis ⇒ reads the code
* Dynamic Analysis ⇒ runs the code.

Sonar Qube

* It is a platform for continuous inspection of code quality & security.

It reports on,
→ Bugs
→ Vulnerabilities.
→ Code smells.
→ Duplications
→ Security Issues.
→ Coverage.
→ Complexity.
→ Maintainability.
→ Reliability.

Features
* static code analysis.
* Integrates with CI/CD pipelines.
* Supports multiple programming languages.

Scanned with OKEN Scanner

Advantages

→ Early bug detection
→ Improved security.
→ Better maintainability.
→ Consistent coding standards
→ Reduced technical debt
→ Automation.

26/09/2

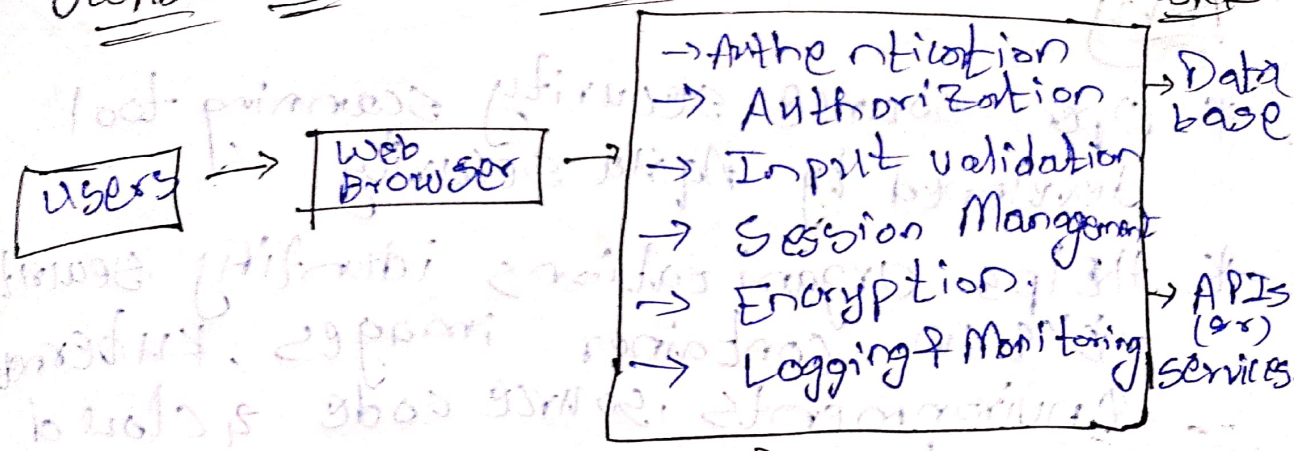
Web Application security

* These refer to the practices, technologies & controls used to protect web applications from cyber threats & vulnerabilities.
* OWASP (Open Worldwide Application security Project), provides industry-standard guidelines, tools & frameworks to help organizations build secure web applications.

→ Protect sensitive data & user info.
→ Prevents unauthorized access
→ Ensure CIA.
→ Secure web applications against common vulnerabilities.
→ Maintain business continuity & user trust

Scanned with OKEN Scanner

OWASP WEB APPLICATION SECURITY FRAMEWORK



Key Features of OWASP ZP

- → Automated vulnerability.
- → Web Application
- → Proxy Interception.
- → Active Scanning.
- → Passive Scanning.
- → API Security testing.
- → Fuzzing.
- → Authentication Testing.

OWASP Security Practices

SDLC Stages		Security Practices
Requirements	→	Security requirements.
Design	→	Threat Modeling.
Coding	→	Secure coding.
Build	→	SAST / SCA
Testing	→	DAST / API Testing.
Deployment	→	Security Configuration
Monitoring	→	Security monitoring.

Scanned with OKEN Scanner

Trivy.

* Open-source security scanning tool developed by Aqua security.
* Helps organizations identify security risks in container images, Kubernetes environments, source code & cloud infrastructure.

→ Trivy automatically scans application for,

* Vulnerabilities (CVEs)
* Misconfigurations.

→ Used in DevSecOps & CI/CD pipelines to detect security problems early in the software development Lifecycle.

03/10/26

Common Categories of secrets

→ API Keys & Tokens
→ Database Credentials
→ SSH Keys & Private Certificates
→ Encryption keys.

Static secrets

* Long-Lived Credentials that remain unchanged until an administrator manually updates or rotates them.

Scanned with OKEN Scanner

Dynamic secrets

* Short-lived, ephemeral credentials generated programmatically on-demand by a secrets manager, for a specific task.

MLOps

* This is a set of unified data engineering objects such as devops, machine learning

DevSecOps

* Development + Security + Operations.
* This integrates security throughout the entire SDLC.

* Requirements → Security → Development → Security Testing → Deployment

Shift Left

* This means finding and fixing security problems as early as possible in the SDLC.

→ In DevSecOps,
* Vulnerabilities discovered early.
* Lower remediation cost.

Scanned with OKEN Scanner

* Automated testing.

DevSecOps Core Principles

→ Security as code.
→ Automation.
→ Continuous security.
→ Shared Responsibility.
→ Fast Feedback.

Security as Code

* Security policies & configuration are represented as code.

Automation

* Security checks should be automated wherever possible.

→ Vulnerability scaling.
→ Dependency scaling.
→ Code analysis.

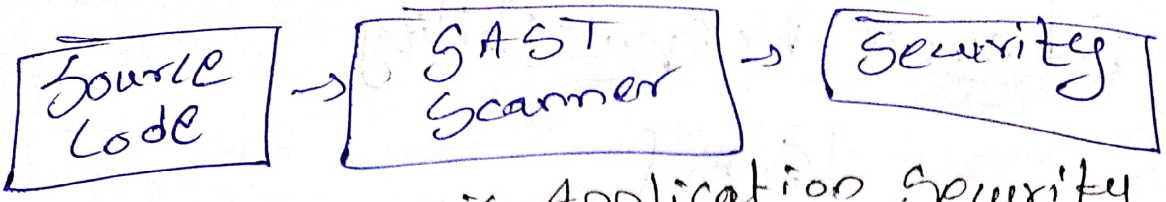
DevSecOps Lifecycle

Plan → Code → Build → Test → Release → Deploy → Operate → Monitor

SAST (Static Application Security Testing)

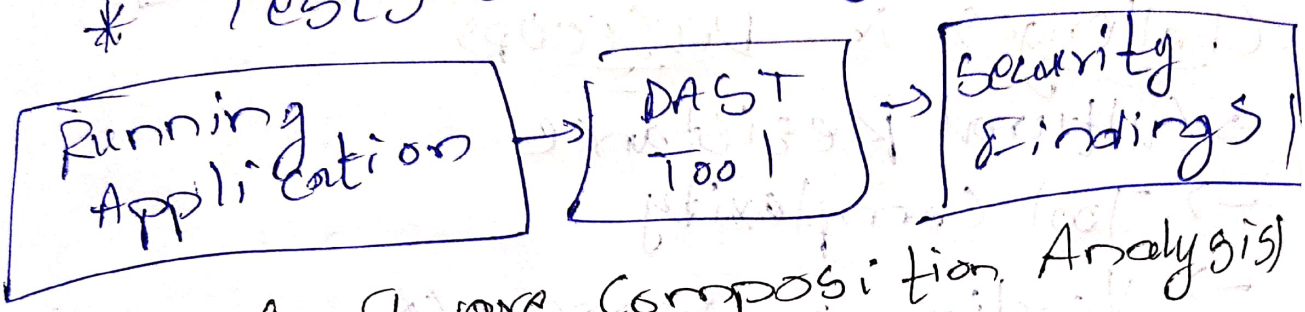
* Analyzes source code without executing the application.

Scanned with OKEN Scanner



DAST (Dynamic Application Security Testing)

* Tests a running application.



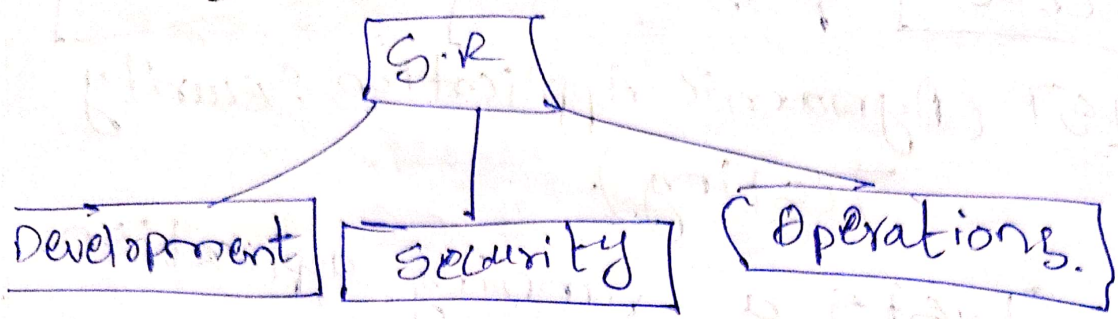
SCA (Software Composition Analysis)

* This identifies,
  - → Vulnerable dependencies.
  - → Outdated packages.
  - → Known CVE's
  - → Licence issues.

Common DevSecOps Security Tools

- → Sonar Qube } SAST
- → Semgrep
- → GitHub Advanced Security
- → OWASP ZAP → DAST
- → Trivy } Dependency & container
- → Snyk } scanning.

Shared Responsibility



Challenges in DevSecOps

→ Cultural Resistance
→ Tool Complexity
→ Pipeline performance.
→ Integration problems.

CVE (Common Vulnerabilities & Exposures)

* Provides standardized identifiers for publicly known security vulnerabilities.

Ex:- Format

CVE - YYYY - NNNNN.

Static Analysis

Source Code
↓
Static Analyzer
↓
Code Inspection
↓
Issues / Bugs

Dynamic Analysis

Source Code
↓
Compile
↓
Execute Program
↓
Monitor Runtime Behavior
↓
Detect Problems

SonarQube Architecture

1) Source code
2) Sonar Scanner
3) SonarQube Server
4) Database
5) SonarQube Web Interface.

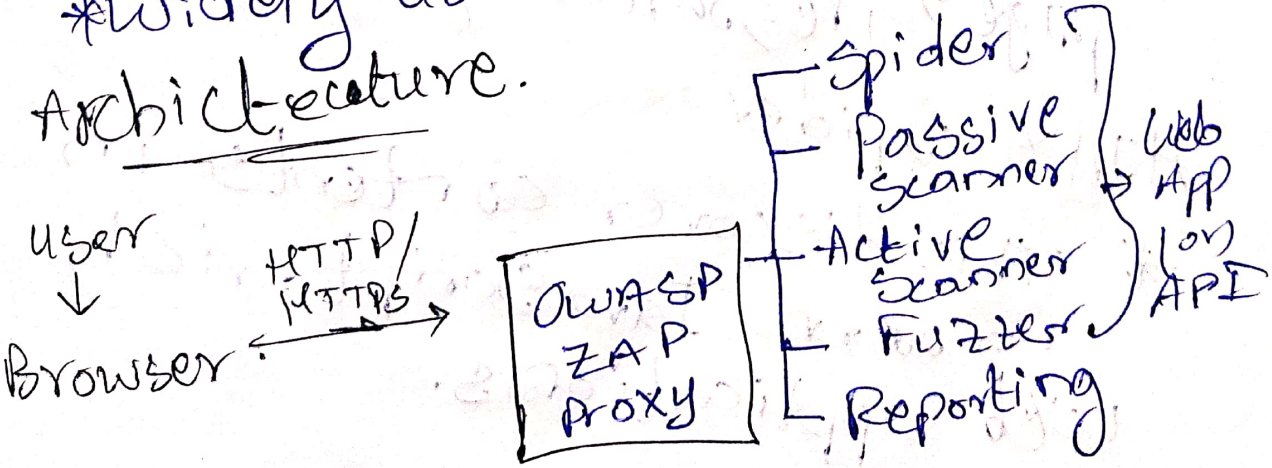
Quality Gate

* This is a set of conditions used to determine whether a project meets defined quality requirements.

OWASP ZAP (Zed Attack Proxy).

* This is a web application security testing tool developed by OWASP.
* Widely used in Devsecops.

Architecture.



Scanned with OKEN Scanner

Passive Scanning

* This analyzes HTTP/HTTPS requests & responses without sending additional requests to the target application.

Active Scanning

* Actively sends attack payloads & malicious inputs to the target application to identify exploitable vulnerabilities.

Spider

* Automated web crawler that explores a web application by following links, forms & URL's to discover all accessible pages, resources & endpoints.

AJAX Spider

* This discover contents in modern JavaScript-rich web applications.

Scanned with OKEN Scanner

Fuzzing

* This is a security testing technique used to discover vulnerabilities by sending large amounts of unexpected, malformed & random or invalid data to application inputs & observing how the application responds.

Authentication Testing

* This verifies whether the login & access control mechanisms of a web application are secure.

Container security in Trivy

* Process of protecting containerized applications from vulnerabilities, malware, secrets exposure.

Trivy Architecture

Key components

→ Inputs
→ Core Engine
→ Security Databases
→ Report Generator
→ Integrations.

Scanned with OKEN Scanner

Image Scanning in Trivy

* Process of analyzing container images to identify security vulnerabilities, exposed secrets.

Filesystem Scanning in Trivy

* Process of scanning local directories files and operating system packages to identify security vulnerabilities, misconfigurations

Kubernetes Security in Trivy

* Scans kubernetes clusters, workloads & configurations to identify security vulnerabilities

Infrastructure as Code

* Analyzes infrastructure configuration files to identify security misconfigurations before deployment

SBOM (Software Bill of Materials)

→ This is a detailed inventory of all software components, libraries & packages & dependencies.

Scanned with OKEN Scanner

Supply Chain Security

*Practice of protecting software from risks introduced through third-party libraries, packages etc..

Role of Trivy in CI/CD

→ Automatically scans code, containers and dependencies.
→ Detects vulnerabilities before deployment.

Secrets Management in DevSecOps.

* This is the systematic discovery, protection, storage, rotation and auditing of credentials across the entire SDLC.

Common Categories of secrets

→ API keys & Tokens.
→ Database Credentials.
→ SSH keys & Private Certificates
→ Encryption keys.

Scanned with OKEN Scanner

Types of Secrets

1) Primary classifications of digital secrets

→ Authentication Credentials.
→ Database Credentials.
→ Cryptographic keys & Certificat
→ Cloud Infrastructure, I.A.M. key
→ Application Configuration Secrets.

2) Engineering Distinction

1) Static secrets ⇒ Long-Lived Credentia
2) Dynamic Secrets ⇒ Short-lived credentials.

Secrets Lifecycle

Creation & Generation
↓
Storage
↓
Distribution / Injection
↓
Revocation & Retirement.

Scanned with OKEN Scanner

GDPR (General Data Protection Regulation)

* This establishes rules for how organizations collect, process, store and share personal data.
* This integrates privacy, security and compliance into every phase of Software Development.

Privacy concepts in GDPR Fundamentals

1) Confidentiality.
2) Integrity.
3) Availability.
4) Transparency.
5) Accountability.
6) Privacy by Design.

Principles

→ Lawfulness
→ Fairness
→ Transparency.
→ Purpose Limitation.
→ Data Minimization.
→ Accuracy.

Scanned with OKEN Scanner

5.) Storage Limitation.

6.) Integrity & Confidentiality.

7.) Accountability.

Audit Trails

* This is a chronological record of activities, events and transactions related to data processing, system access, and security operations.

Scanned with OKEN Scanner